Industrial Security (Bachelor)

Exercise Sheet – Section 08

Defense in Depth

Goal. Move from the defense-in-depth onion (policies, physical, segmentation, host hardening, application/RBAC, data/backups, monitoring/IR) to concrete decisions you can defend in front of a plant manager. The questions are scenario-driven: pick real products, real standards (NIST SP 800-82 R3, IEC 62443-3-3, INL DiD 2016), and explain the controls in operational language. There is rarely one correct answer – there is a defensible one.

Exercise 8.1 – Vendor PLC Download Workflow

A Siemens field engineer needs to download a logic change to a S7-1500 PLC on Purdue Level 2 of your plant. Design the end-to-end secure remote-access workflow.

1. Draw the path from the vendor's laptop to the PLC. Name every hop (broker, jump host, industrial firewall) and at least one concrete product per hop (Cyolo, Claroty SRA, BeyondTrust PRA, Cisco Secure Equipment Access, . . .).
2. Mark where MFA is enforced, where the session is recorded, and which on-shift role clicks "approve".
3. Describe the audit trail: which artefacts persist after the session ends and where they are stored.
4. State one failure mode (e.g. broker outage, vendor MFA reset) and how the design tolerates it without granting standing access.

Exercise 8.2 – "Flat VPN, Like Everywhere Else"

A turbine vendor demands a flat IPsec VPN into Level 2 "because that is how we have it everywhere else." Write a one-page counter-proposal addressed to the vendor's account manager.

1. Acknowledge the operational need (firmware updates, vibration tuning, warranty visits).
2. Propose a brokered alternative aligned with IEC 62443-3-3 SR 1.13 and SR 2.4 and explain how it preserves vendor productivity.
3. List the three risks of flat VPN you are unwilling to accept (lateral movement, persistence after the session, no per-action audit).
4. Offer a 30-day pilot scope so the vendor cannot reject the change as "too disruptive".

Exercise 8.3 – Passive OT IDS Placement

You have three remote substations (each with a managed switch and two IEDs), one central historian, and one SCADA HMI, linked by a WAN. You will deploy a passive IDS sensor (Zeek/-Malcolm, Claroty CTD, Nozomi Guardian, Dragos Platform, Cisco Cyber Vision, or Forescout SilentDefense).

1. Mark where you tap (SPAN port vs. hardware TAP) and justify the choice per location.
2. Specify which VLANs you mirror at each site and which you deliberately do not.
3. Name one class of traffic you will *miss* with this placement and a compensating control that closes the gap.
4. Estimate sensor count and where the management plane lives.

Exercise 8.4 – Three Layers, One Logo

"Defense in depth" is not the same control three times. Give one realistic example of an apparent layered defense that is actually a single point of failure ("three layers, one logo").

1. Name the three controls and the shared dependency (vendor, OS, identity provider, library).
2. Describe a single failure that defeats all three at once.
3. Propose how you would restore independence (different vendor at one layer, out-of-band identity, different OS family).

Exercise 8.5 – "Just 5 Minutes With My Own Laptop"

A third-party contractor wants to plug his own laptop into the OT network for "just 5 minutes" to read a diagnostic file. Your plant uses an OPSWAT MetaDefender Kiosk for USB and a Forescout/Cisco ISE NAC for the wall jacks. Write the procedure your security operations would follow.

1. State the default answer and which standard or internal policy backs it (IEC 62443-3-3 SR 1.1/SR 1.2, INL DiD 2016 §5).
2. If the read genuinely cannot wait, describe the workaround that does *not* put the laptop on the OT VLAN (kiosk export to sanitised USB, jump-host file pull, vendor-owned thin client).
3. List the controls that must be in place *before* you say "yes" (NAC quarantine VLAN, full-disk EDR, recorded session).
4. Specify the audit-trail entries the SOC must capture.

Exercise 8.6 – Backup Plan for a Mixed Plant

You inherit a plant with these assets:

- one Schneider Modicon M580 PLC running production logic,
- one Wonderware (AVEVA) HMI server,
- one SQL Server historian (300 GB, 90-day retention),
- twelve managed switches (Cisco IE-3400 / Hirschmann mix).

For each asset, specify: backup type (configuration, full image, database dump, switch running-config), tool (Schneider EcoStruxure Control Expert, Veeam, native SQL backup, RANCID/Oxidized), frequency, retention, off-site/immutable target, and restore-test cadence. Apply the 3-2-1 rule and call out the immutable copy.

Exercise 8.7 – Compensating Controls for an Un-Replaceable Windows 7 HMI

A Windows 7 HMI cannot be replaced for 2 years (vendor recertification pending). Patches stopped in 2020. List five compensating controls in priority order and explain what each protects against.

1. Rank from highest to lowest impact-per-effort.
2. Map each control to the layer it sits in (segmentation, host, identity, monitoring, process).
3. Name a concrete product or technique per control (micro-segmentation via Tofino/Cisco ISA-3000, application allow-listing with McAfee Solidcore or AppLocker, virtual patching via Trend Micro TippingPoint, . . .).
4. State one residual risk that no compensating control closes.

Exercise 8.8 – OT Log Sources Your Enterprise SIEM Misses

Your company runs Splunk Enterprise Security. List five OT-specific log sources that Splunk does *not* parse out of the box, and propose how you would normalise each into the SIEM.

1. Pick concrete sources (S7Comm session events from a Cyber Vision sensor, IEC 60870-5-104 ASDU logs, PLC RUN/STOP transitions, HMI alarm-history rows from a Wonderware Galaxy DB, jump-host session metadata from BeyondTrust, . . .).
2. For each, name the producer, the wire format, and the Splunk add-on or custom parser you would deploy (Splunk OT Add-on, Dragos integration, custom CIM mapping, Cribl pipeline).
3. Propose one cross-source correlation rule that becomes possible after onboarding.

Exercise 8.9 – Honey-PLC Deployment Plan

Design a deception layer for your plant.

1. Pick the product (Thinkst Canary, conpot, MushMush honeypot, or a custom Siemens-S7-flavoured Cowrie variant) and justify the choice.
2. Decide what it should expose (Modbus/TCP 502, S7Comm 102, EtherNet/IP 44818, web UI on 80/443) and pick a name that fits your real asset convention (e.g. `LINE3-PLC-07`).
3. State where it lives on the Purdue model and on which VLAN.
4. Wire up at least two alerts (SIEM rule, SOC chat channel, on-call rotation) and define what triage looks like for a single hit.

Exercise 8.10 – Spot the Bug: NAC Config

A junior engineer has configured NAC so that any device presenting a MAC OUI from "Dell Inc." is admitted to the Level 3 supervisory VLAN via 802.1X MAC Authentication Bypass (MAB), with no further checks. The justification is: "IT vendor laptops are always Dell."

1. Identify three weaknesses in this configuration (MAC spoofing trivial, OUI shared with thousands of devices, no posture check, no time-bound access, wrong Purdue level for a transient device).
2. Propose three fixes in increasing order of operational cost (move device profile from OUI-only to certificate-based, add Forescout/ISE posture check, terminate the laptop in a vendor DMZ VLAN with a brokered jump rather than Level 3 directly).
3. State the standard or guidance that supports each fix (IEEE 802.1X-2020, NIST SP 800-82 R3 §6, IEC 62443-3-3 SR 1.1).